# Data leak worksheet

**Incident summary:** A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new product that has not been publicly announced. It also included customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials with others.

During a video call with a business partner, a member of the sales team forgot the warning from their manager. The sales representative intended to share a link to the promotional materials so that the business partner could circulate the materials to their customers. However, the sales representative accidentally shared a link to the internal folder instead. Later, the business partner posted the link on their company's social media page assuming that it was the promotional materials.

| **Control** | **Least privilege** |
| --- | --- |
| **Issue(s)** | *What factors contributed to the information leak?*<br><br>*Several things went wrong together. The manager left the whole internal folder open after the meeting, even if the team only needed the promotional files, and the folder also had the unannounced product and customer analytics. The only protection was a spoken warning. The sharing settings also allowed a link to the folder to be sent to people outside the company. The sales representative picked the wrong link by mistake, and the business partner posted it publicly without checking what it was.* |
| **Review** | *What does NIST SP 800-53: AC-6 address?*<br><br>*AC-6 is the least privilege control. It says that users should get only the minimum access and authorization they need to do their task, and nothing more. Accounts, roles and processes should be set up so that nobody works with higher privileges than necessary.* |
| **Recommendation(s)** | *How might the principle of least privilege be improved at the company?* |

| | |
|---|---|
| | *Access to the folder should depend on the job. The promotional materials should live in a separate folder that is safe to share, and the internal folder should stay restricted to the people who need it. Access given for a meeting should expire at the end of it, or be removed by the manager right after. Links to internal files should work only for company accounts, and sharing with external people should need an approval. Regular reviews of who can open what, and short training on sharing links, would also help.* |
| **Justification** | *How might these improvements address the issues?*<br><br>*A separate folder for public material means that a wrong click shares something harmless. Automatic expiry removes the problem of a manager forgetting to revoke access. Blocking links for external users would have stopped the leak even after the mistake, and the review and the training lower the chance that the same thing happens again.* |

## Security plan snapshot

The NIST Cybersecurity Framework (CSF) uses a hierarchical, tree-like structure to organize information. From left to right, it describes a broad security function, then becomes more specific as it branches out to a category, subcategory, and individual security controls.

| Function | Category | Subcategory | Reference(s) |
|---|---|---|---|
| **Protect** | PR.DS: *Data security* | PR.DS-5: *Protections against data leaks.* | NIST SP 800-53: AC-6 |

In this example, the implemented controls that are used by the manufacturer to protect against data leaks are defined in NIST SP 800-53—a set of guidelines for securing the privacy of information systems.

**Note:** References are commonly hyperlinked to the guidelines or regulations they relate to. This makes it easy to learn more about how a particular control should be implemented. It's common to find multiple links to different sources in the references columns.

## NIST SP 800-53: AC-6

NIST developed SP 800-53 to provide businesses with a customizable information privacy plan. It's a comprehensive resource that describes a wide range of control categories. Each control provides a few key pieces of information:

- **Control:** A definition of the security control.
- **Discussion:** A description of how the control should be implemented.
- **Control enhancements:** A list of suggestions to improve the effectiveness of the control.

| | |
|---|---|
| **AC-6** | **Least Privilege** |
| | Control:<br>Only the minimal access and authorization required to complete a task or function should be provided to users. |
| | Discussion:<br>Processes, user accounts, and roles should be enforced as necessary to achieve least privilege. The intention is to prevent a user from operating at privilege levels higher than what is necessary to accomplish business objectives. |
| | Control enhancements:<br>● Restrict access to sensitive resources based on user role.<br>● Automatically revoke access to information after a period of time.<br>● Keep activity logs of provisioned user accounts.<br>● Regularly audit user privileges. |

**Note:** In the category of access controls, SP 800-53 lists least privilege sixth, i.e. AC-6.